

Enterprise Google Cloud Data Platform Blueprint

Volume 08: Security and Zero Trust

Enterprise Reference Architecture and Implementation Blueprint

Version 1.0 | 12 July 2026 | Google Cloud

Prepared for enterprise architecture review, security architecture review, Cloud Center of Excellence, data governance council, regulatory and compliance review, platform engineering implementation, production readiness review and financial approval. This volume extends Volumes 1-7 and does not regenerate or modify them.

Document Control

Field	Value
Document	Volume 08 - Security and Zero Trust
Series	Enterprise Google Cloud Data Platform Blueprint
Version	1.0
Status	Detailed reference architecture for adaptation and implementation
Date	12 July 2026
Owner	Enterprise Security Architecture
Approvers	CISO, CIO, CDO, Enterprise Architecture, Privacy, Risk, Platform Engineering, SRE, DevSecOps, FinOps
Audience	Security architects, cloud platform engineers, data platform owners, domain teams, SRE, audit, compliance and risk
Primary dependencies	Volumes 01-07; Volume 09 DevSecOps; Volume 10 FinOps; Volume 11 SRE; Volume 12 DR; Volume 13 Terraform
Scope	Enterprise security strategy, Zero Trust architecture, IAM, perimeters, encryption, data protection, detection, incident response, testing and compliance control mapping

Classification of guidance: Mandatory baseline controls are required unless a time-bound exception is approved by the Security Architecture Review Board. Recommended controls are the enterprise default for most workloads. Conditional controls apply to regulated, restricted, externally exposed or high-risk workloads. Future-state controls are planned capabilities that require product, licensing or operating-model validation.

Table of Contents

1. Executive Summary
2. Inherited Context, Scope and Assumptions
3. Enterprise Security Strategy
4. Shared-Responsibility Model
5. Zero Trust Architecture
6. Identity Perimeter
7. Network Perimeter
8. Data Perimeter
9. Workload Perimeter
10. IAM Architecture
11. Human Identities
12. Workload Identities and Service Accounts
13. Privileged Access, JIT and Break-Glass
14. Separation of Duties
15. Organization Policies
16. VPC Service Controls
17. Access Context Manager
18. Private Service Connect
19. Cloud Armor and Cloud Firewall
20. Security Command Center and Threat Detection
21. Secret Manager, Cloud KMS, Cloud HSM, CMEK and EKM
22. Certificate Management
23. Sensitive Data Protection
24. Data Classification, Tokenization, Masking and Pseudonymization
25. Audit Logging, Access Transparency and Access Approval
26. Supply Chain Security
27. Vulnerability Scanning
28. Security Monitoring, SIEM and SOAR
29. Threat Modeling, STRIDE and Attack Path Analysis
30. Incident Response
31. Regulatory Control Mapping
32. Security Testing and Penetration Testing
33. Security Assurance and Architecture Review
34. Service Assessments
35. Architecture Decision Records
36. Risks and Mitigations
37. Implementation Roadmap
38. Validation Criteria
39. Production Readiness Checklist
40. Decisions and Next Actions
41. References

1. Executive Summary

Volume 08 defines the security and Zero Trust architecture for the enterprise Google Cloud data platform. The platform handles petabytes of data across multiple regions, legal entities, regulated workloads, business domains, analytics personas and AI/GenAI use cases. Security is not treated as an isolated layer added after delivery. It is embedded in the identity model, project hierarchy, service perimeters, network paths, data classification, encryption controls, software supply chain, monitoring and operating model established across Volumes 1-7.

The target posture is a governed, cloud-native, auditable and automation-first Zero Trust model. Every access path must prove identity, context, authorization, data purpose and workload integrity. Project membership, source IP and internal network location are not sufficient proof of trust. The architecture uses Workforce Identity Federation, Workload Identity Federation, IAM Conditions, Privileged Access Manager, service account impersonation, VPC Service Controls, Access Context Manager, Private Service Connect, Cloud Armor, Cloud Firewall, Cloud KMS, Cloud HSM, Cloud EKM where justified, Sensitive Data Protection, Security Command Center, Event Threat Detection, Container Threat Detection, Artifact Analysis, Binary Authorization, Cloud Audit Logs, Access Transparency, Access Approval and SIEM/SOAR integration.

Security outcome	Mandatory baseline
Least privilege	Group-based IAM, IAM Conditions, deny policies where appropriate, no broad primitive roles in production, quarterly access review.
No long-lived workload keys	Workload Identity Federation and service account impersonation are the default. User-managed service account keys are disabled unless exception-approved.
Data exfiltration control	VPC Service Controls, Private Service Connect, Access Context Manager, restricted APIs and explicit egress rules for restricted and regulated data.
Encryption and key control	Google default encryption everywhere; CMEK for Confidential, Restricted and Regulated workloads where supported; HSM or EKM when risk or regulation requires.
Privacy by design	Sensitive Data Protection profiling, classification, de-identification, masking, tokenization, pseudonymization and policy tags.
Detection and response	Security Command Center, threat detection, audit log routing, SIEM/SOAR playbooks and immutable evidence retention.
Supply-chain assurance	Artifact Analysis, Binary Authorization, signed provenance, vulnerability gates and deployment controls.

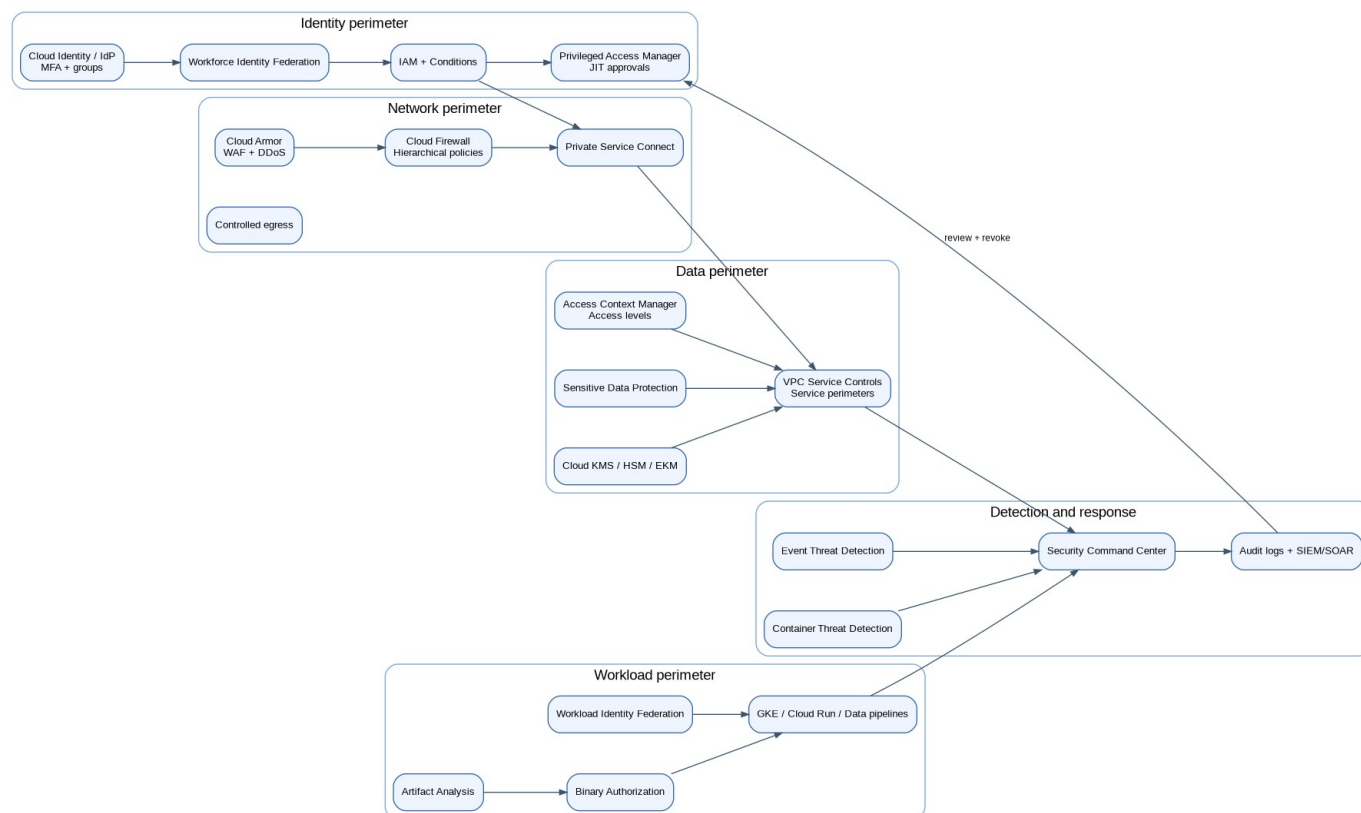


Figure 1 - Enterprise security and Zero Trust reference architecture

2. Inherited Context, Scope and Assumptions

2.1 Inherited architecture context

- The enterprise organization uses a central platform product team and federated domain-owned data products.
- Core data services include Cloud Storage, BigQuery, BigLake where justified, Pub/Sub, Dataflow, Datastream, Dataform, Cloud Composer, Knowledge Catalog, Looker and Vertex AI.
- Project strategy separates shared services, network, security, logging, monitoring, CI/CD, data platform and domain workloads.
- AMER, EMEA and APAC regional data planes are used with centrally governed controls and regional resilience targets.
- Security classifications are Public, Internal, Confidential, Restricted and Regulated.
- Tier 0, Tier 1 and Tier 2 recovery targets from the foundation remain applicable, with security evidence and key availability considered critical dependencies.
- Volume 06 analytics and Volume 07 AI/GenAI require this security baseline for production access, model protection and regulated consumption.

2.2 Confirmed requirements

- Produce only Volume 08 and do not regenerate Volumes 1-7.
- Follow the master blueprint scope and structure for Security and Zero Trust.
- Provide regulatory control mappings for NIST, HIPAA, GDPR, PCI DSS, SOC 2 and ISO 27001.
- Generate diagrams, matrices, implementation examples, ADRs, risks, validation criteria and production readiness checks.
- Use current Google Cloud product terminology and clearly identify items that require validation at implementation time.

2.3 Architecture assumptions

- The enterprise uses a primary corporate identity provider integrated with Cloud Identity and Google Cloud federation.
- Security Command Center is activated at the organization level for production and regulated environments.
- Enterprise SIEM and SOAR platforms exist and require log and finding integration from Google Cloud.
- Regulated workloads require stronger data residency, personnel access, key management and audit evidence.
- Terraform is the system of record for deployable infrastructure and policy configuration, with exception records managed in GRC tooling.

2.4 Open architecture decisions

Open decision	Decision owner	Required before
Which workloads require Cloud HSM versus software Cloud KMS versus EKM	CISO, Compliance, KMS team	Production onboarding for Restricted/Regulated data
Which Google Cloud services are enrolled in Access Approval by default	CISO, Cloud Platform	Regulated workload go-live
Which third-party endpoint posture signals are used in custom Access Context Manager levels	IAM Governance	Broad workforce rollout
SIEM retention period and log export partitioning strategy	Security Operations, Audit	Production logging deployment
Cloud Armor Enterprise adoption for external applications	Network Security, FinOps	Internet-facing analytics or API exposure

3. Enterprise Security Strategy

The security strategy is to make the secure path the fastest path. Controls are deployed as reusable platform capabilities, not one-off project tasks. Domain teams consume approved modules, groups, labels, key policies, service perimeters, CI/CD gates and runbooks. The central security architecture team owns baseline design and standards. Platform engineering owns reusable implementations. Domain teams own secure operation of their data products and evidence for their workloads.

3.1 Strategy pillars

Pillar	Concrete architecture decision	Evidence
Identity-first security	Federated identity, group-based access, IAM Conditions, PAM for elevation	IAM policies, access reviews, PAM grants
Data perimeter protection	VPC Service Controls for restricted APIs and projects	Perimeter configs, dry-run logs, denied access tests
Private connectivity	Private Service Connect and private API paths for sensitive workloads	Network path evidence and route validation
Cryptographic control	CMEK/HSM/EKM based on classification and regulation	KMS key inventory, rotation logs, key access logs
Privacy engineering	Sensitive Data Protection profiling and de-identification	Profiles, templates, policy tags, masking evidence
Continuous assurance	SCC, audit logs, SIEM/SOAR, posture monitoring	Findings, alerts, tickets, exceptions
Secure delivery	Artifact Analysis, Binary Authorization, policy-as-code	Build provenance, scan reports, attestation logs

3.2 Mandatory controls

- All production human access must use enterprise identity, MFA and group-based authorization.
- All production workload access must use service accounts with least privilege and short-lived credentials.
- User-managed service account keys are prohibited by organization policy unless explicitly exception-approved.
- Restricted and Regulated projects must be inside an approved VPC Service Controls perimeter when supported by required services.
- CMEK is mandatory for Restricted and Regulated storage/analytics/AI services where the service supports CMEK and regional requirements can be met.
- Sensitive Data Protection profiling must be enabled for high-value production datasets and document repositories.
- Security Command Center findings, Cloud Audit Logs and policy denied logs must be routed to central security monitoring.
- Production deployments must pass vulnerability scanning and attestation gates before runtime deployment.

4. Shared-Responsibility Model

Google Cloud secures the underlying global infrastructure, managed service control planes and foundational service protections. The enterprise is responsible for identity, authorization, data classification, policy configuration, service perimeter design, key lifecycle, secure application and pipeline behavior, log review, incident response and compliance evidence. Shared responsibility changes by service: fully managed services reduce infrastructure operations, but they do not remove data-owner, access-governance or configuration responsibilities.

Responsibility	Google Cloud	Enterprise platform team	Domain/workload team	Security/risk
Physical/data-center security	Responsible	Consume assurance reports	No direct action	Review attestations
IAM policy design	Provides IAM service	Defines baseline roles and groups	Requests least privilege access	Approves privileged models
Data classification	Provides tools such as SDP/KC	Defines taxonomy and tooling	Classifies data products	Reviews regulated mappings
Service perimeter config	Provides VPC SC/ACM	Builds perimeters and modules	Defines approved flows	Validates exfiltration controls
Encryption keys	Provides Cloud KMS/HSM/EKM integrations	Creates key hierarchy and modules	Selects classification and service mappings	Owns custodianship and policy
Threat detection	Provides SCC and detections	Routes findings and logs	Responds to workload findings	Runs incident process
Compliance evidence	Provides logs and attestations	Automates exports	Supplies workload evidence	Maps controls and manages audits

5. Zero Trust Architecture

The platform applies Zero Trust through four enforcement planes: identity perimeter, network perimeter, data perimeter and workload perimeter. Each plane contributes independent evidence. A request to a restricted data product is allowed only when identity, group membership, device/network context, resource classification, data purpose, service perimeter, key permission and workload integrity are aligned.

5.1 Zero Trust decision flow

- 42. Authenticate the subject through enterprise federation or workload federation.
- 43. Evaluate identity group, role, condition, device posture, source network and access level.
- 44. Evaluate resource sensitivity, service perimeter, ingress/egress rule and approved data purpose.
- 45. Evaluate workload identity, artifact trust, runtime posture, vulnerability state and deployment provenance.
- 46. Permit the minimum required action, record audit evidence and continuously monitor for drift or anomalous behavior.

Control plane	Trust question	Primary services
Identity	Who is requesting access and under what assurance?	Cloud Identity, Workforce Identity Federation, IAM, IAM Conditions, PAM
Network	Is the path private, expected and controlled?	Shared VPC, Private Service Connect, Cloud Firewall, Cloud Armor, Cloud NAT
Data	Is the data allowed to move to this subject and destination?	VPC Service Controls, Access Context Manager, Sensitive Data Protection, BigQuery policies, KMS
Workload	Is the code, build and runtime trusted?	Workload Identity Federation, Artifact Analysis, Binary Authorization, GKE, Cloud Run
Operations	Is the action observable and recoverable?	Cloud Audit Logs, SCC, Event Threat Detection, SIEM, SOAR, runbooks

6. Identity Perimeter

The identity perimeter establishes who can access enterprise resources and under which assurance level. Human identities are federated from the enterprise identity provider into Google Cloud. Workload identities are federated from approved build systems, Kubernetes platforms and external clouds. Cloud Identity groups remain the authorization unit. Direct user grants are prohibited in production except for emergency break-glass identities that are governed through PAM and audit review.

- Use group naming aligned to environment, domain, role and classification.
- Use IAM Conditions for time, resource name, request reason and context-dependent grants.
- Use deny policies for high-risk operations such as service account key creation where appropriate.
- Review privileged groups monthly and standard product access quarterly.

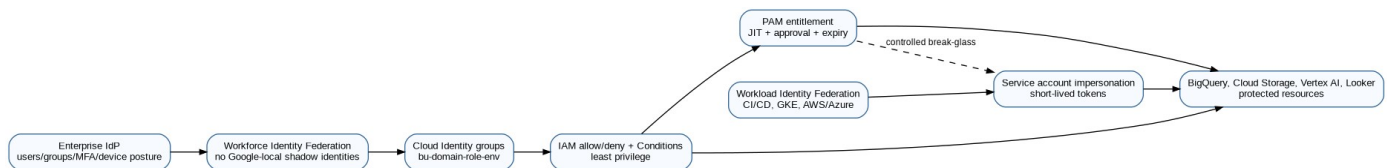


Figure 2 - Identity trust boundary and federation model

7. Network Perimeter

The network perimeter controls connectivity, ingress, egress and exposure. The data platform uses Shared VPC, hierarchical firewall policies, Private Google Access, Private Service Connect, Cloud NAT and Cloud Armor for internet-facing services. Network location alone is never sufficient authorization, but private paths reduce exposure and simplify monitoring.

- Deny all non-approved ingress by default through hierarchical firewall policies.
- Centralize egress through monitored NAT or proxy patterns for workloads that require internet access.
- Use Private Service Connect for API access and producer/consumer service exposure.
- Use Cloud Armor for external applications, APIs and portals that expose analytics, data products or operational interfaces.

8. Data Perimeter

The data perimeter protects APIs and managed services that host or process enterprise data. VPC Service Controls is the primary exfiltration-reduction control for restricted projects. Access Context Manager supplies access levels based on identity, network, device and contextual attributes. Perimeter design is product-aware because supported services and interfaces must be validated before enforcement.

- Start VPC Service Controls in dry-run mode for new perimeters.
- Model approved ingress and egress explicitly before enforcement.
- Review policy denied logs daily during rollout and continuously in production.
- Do not use VPC Service Controls as a replacement for IAM, encryption, classification or application security.

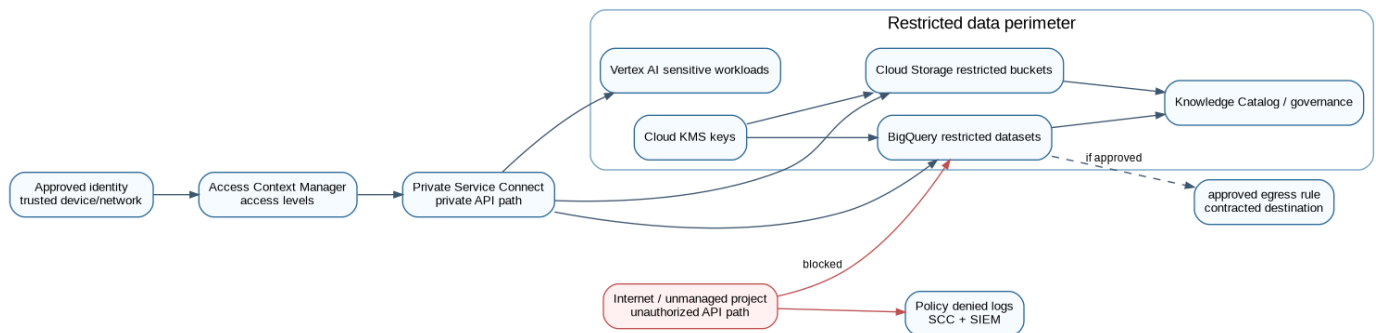


Figure 3 - VPC Service Controls and context-aware data perimeter

9. Workload Perimeter

The workload perimeter protects pipelines, containers, serverless services, analytics engines and AI workloads. It verifies where code came from, whether the artifact was scanned, whether the deployment was approved and whether runtime identity is scoped. The workload perimeter is especially important for Dataflow, Cloud Run, GKE, Composer, Dataform, Vertex AI and CI/CD agents.

- Use Workload Identity Federation for external build and runtime platforms.
- Attach one service account per deployable workload and environment.
- Require Artifact Analysis and Binary Authorization for containerized production workloads.
- Route runtime security signals into Security Command Center and SIEM.

10. IAM Architecture

IAM uses a layered model: resource hierarchy guardrails, group-based functional access, service-specific custom roles where needed, IAM Conditions for context, deny policies for prohibited actions and PAM for privileged elevation. The platform avoids permanent project-owner grants. Access decisions are documented in an access matrix and periodically reviewed.

- Prefer predefined roles before custom roles, and custom roles before broad basic roles.
- Apply IAM at the narrowest practical resource boundary.
- Avoid direct user grants in production.
- Automate IAM drift detection using Cloud Asset Inventory exports.

11. Human Identities

Human access uses enterprise SSO, MFA, trusted device posture and group membership. Workforce Identity Federation is the preferred pattern for external workforce identities. Cloud Identity groups represent roles such as platform security admin, data product owner, domain steward, analytics consumer and SRE on-call. Privilege elevation happens through PAM, not standing administrative membership.

- Require MFA and approved IdP session policies.
- Map identity lifecycle events from HR and partner systems to access removal.
- Use break-glass identities only for emergency recovery and test them periodically.
- Block local unmanaged identities for production administration.

12. Workload Identities and Service Accounts

Workload identity design removes long-lived secrets and creates auditable workload-to-resource relationships. CI/CD systems, GKE workloads, AWS/Azure workloads and self-hosted systems authenticate through Workload Identity Federation or approved service account impersonation. Service accounts are named by domain, function, environment and data classification.

- Disable service account key creation and upload by organization policy.
- Use Service Account Token Creator only for approved impersonation paths.
- Separate build, deploy, runtime and break-glass service accounts.
- Log both the impersonated service account and the principal that generated short-lived credentials.

13. Privileged Access, JIT and Break-Glass

Privileged access is a controlled exception flow. Privileged Access Manager provides approval, time-bound access, justification and audit logs for elevated roles. Break-glass access is reserved for incidents where normal controls prevent recovery and must be tied to an incident ID, post-use review and compensating controls.

- Define PAM entitlements for platform security, SRE, KMS custodians and incident commanders.
- Limit privileged elevation duration to the minimum operational window.
- Require dual approval for Regulated or Restricted access.
- Alert on every break-glass grant and include it in monthly security review.

14. Separation of Duties

Separation of duties prevents a single actor from developing, approving, deploying and operating high-risk changes without independent review. The architecture separates code authors, approvers, deployment service accounts, KMS custodians, data owners and security reviewers.

- Developers cannot approve their own production deployment.
- KMS key administrators cannot decrypt regulated data by default.
- Data owners approve data access, while platform teams implement the technical grant.
- Security operations can contain incidents but production restoration follows change control.

15. Organization Policies

Organization policies enforce non-negotiable guardrails across the resource hierarchy. They prevent dangerous configuration states such as external IP use, service account keys, public buckets, unrestricted resource locations and disabled audit logs. Policies are introduced in dry-run or monitor mode where supported before enforcement.

- Manage organization policies through Terraform.
- Document each exception with owner, expiry and compensating controls.
- Validate policy inheritance across folders and projects.
- Use labels and tags to scope conditional policies to environment and classification.

16. VPC Service Controls

VPC Service Controls creates security perimeters around selected Google Cloud resources and services to reduce the risk of data exfiltration through Google Cloud APIs. It is mandatory for Restricted and Regulated data projects when the required services and access patterns are compatible. The architecture uses separate perimeters for restricted data, AI/GenAI production workloads and governance/logging projects where required.

Design element	Baseline
Perimeter model	Start with dry-run, observe policy denied logs, then enforce after approved tests.
Ingress	Approved identities, identity groups, service accounts and trusted access levels only.
Egress	Explicit destination resources and services; no wildcard egress for restricted data.
Bridge perimeters	Used sparingly for shared governance services after threat review.
Unsupported services	Documented as exception with compensating controls, monitoring and review trigger.

17. Access Context Manager

Access Context Manager supplies access levels based on client attributes including IP address, user identity and device attributes. In the data platform, access levels are used with VPC Service Controls ingress policies, context-aware administrative access and high-trust paths for regulated data. Access levels must be named, versioned and tested as policy artifacts.

18. Private Service Connect

Private Service Connect is used to access Google APIs privately and expose producer services to consumers without broad network peering. It is the preferred pattern for sensitive API paths, internal data services, centrally shared APIs and managed service connectivity when a private consumer-producer pattern is required.

19. Cloud Armor and Cloud Firewall

Cloud Armor protects external application entry points such as data-product portals, APIs, model-serving endpoints and embedded analytics applications from L3/L4 and L7 DDoS and application-layer attacks. Cloud Firewall and hierarchical firewall policies enforce network segmentation and back-end traffic policy. Firewall logging is required for deny rules and high-risk allow rules.

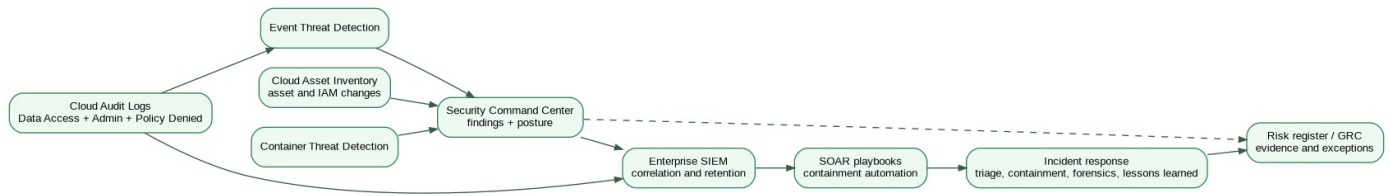


Figure 4 - Security operations detection and response flow

20. Security Command Center and Threat Detection

Security Command Center is the central Google Cloud security and risk plane. It aggregates findings for misconfigurations, vulnerabilities, toxic combinations, threat detections, container runtime attacks and compliance posture. Event Threat Detection and Container Threat Detection generate findings that must be routed to the enterprise SIEM/SOAR with severity, asset owner and data classification enrichment.

Signal	Source	Action
Anomalous IAM grant	Event Threat Detection / audit logs	Contain account, review change, revoke grant if unauthorized.
Container runtime attack	Container Threat Detection	Isolate workload, preserve logs, redeploy signed artifact.
Public bucket or dataset	SCC posture finding	Block public access, open incident for sensitive data.
VPC SC policy denied spike	Policy denied logs	Investigate exfiltration attempt or misconfigured workload.
KMS unusual key access	KMS audit logs	Review principal and workload, rotate if compromise suspected.

21. Secret Manager, Cloud KMS, Cloud HSM, CMEK and External Key Manager

Secret Manager stores sensitive configuration such as API tokens and partner credentials that cannot be eliminated. Cloud KMS provides key management for CMEK, application encryption and signing use cases. Cloud HSM is used when hardware-backed key protection is required. Cloud EKM is conditional for workloads where key material must remain outside Google Cloud or where sovereign/regulatory requirements demand external control. Key Access Justifications should be evaluated with EKM for regulated workloads.

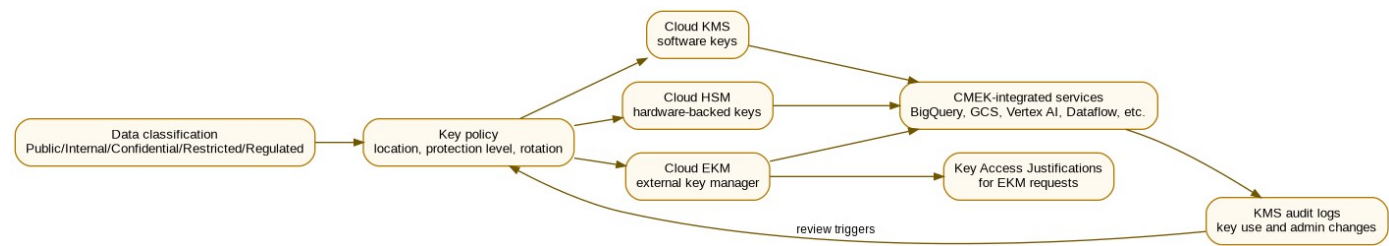


Figure 5 - Cryptographic key management model

Classification	Encryption baseline	Key protection pattern
Public	Google default encryption	CMEK optional only for consistency.
Internal	Google default encryption	CMEK recommended for shared enterprise stores.
Confidential	Google default + CMEK where supported	Software Cloud KMS or HSM based on risk.
Restricted	CMEK mandatory where supported	HSM recommended; strict service-agent IAM.
Regulated	CMEK mandatory and region-aware	HSM/EKM evaluated by compliance and legal.

22. Certificate Management

Certificate Manager is the standard control for TLS certificates used with Cloud Load Balancing. Certificates must be centrally inventoried, automatically renewed where possible and aligned to approved DNS ownership. Private certificate authority requirements are handled by the enterprise PKI or Certificate Authority Service where applicable.

23. Sensitive Data Protection

Sensitive Data Protection supports inspection, profiling, de-identification, masking, redaction, tokenization and pseudonymization. It is required for Restricted and Regulated raw data onboarding, non-production data preparation, analytics exports, document ingestion and GenAI/RAG corpora. Domain teams own business classification; the privacy engineering team owns templates and policy standards.

24. Data Classification, Tokenization, Masking and Pseudonymization

Technique	Use case	Production rule
Data classification	Determine controls, owners, retention, access and key policy	Required for all certified data products.
Masking	Reduce exposure in reports, logs and non-sensitive operations	Use dynamic masking or transformed views for analytics.
Tokenization	Preserve joins while hiding direct identifiers	Use reversible tokenization only with approved key custody.
Pseudonymization	Reduce exposure while preserving analytical utility	Mandatory evaluation for health, financial and HR identifiers.
Redaction	Remove data with no business need	Use for logs, prompts, exports and non-production copies.

25. Audit Logging, Access Transparency and Access Approval

Cloud Audit Logs are required for answering who did what, where and when across Google Cloud resources. Admin Activity, Data Access, System Event and Policy Denied logs must be captured according to workload classification and routed to protected logging projects. Access Transparency provides logs for Google personnel access to customer content in supported services. Access Approval provides a consent workflow for selected Google personnel access requests and is required for regulated workloads after supported services are validated.

26. Supply Chain Security

Supply-chain controls prevent unreviewed or vulnerable artifacts from running in production. Build systems authenticate with Workload Identity Federation, generate provenance, scan artifacts, store them in Artifact Registry and publish attestations. Binary Authorization enforces that only approved, scanned and signed containers are deployed to production GKE or applicable runtime targets.



Figure 6 - Secure software supply-chain gate for production workloads

27. Vulnerability Scanning

Vulnerability scanning combines Artifact Analysis, Security Command Center posture findings, container runtime signals and third-party enterprise scanners where required. Findings are prioritized by exploitability, exposed surface, data classification, workload tier and business criticality. Critical vulnerabilities in internet-exposed or Restricted/Regulated workloads require emergency remediation or compensating control approval.

28. Security Monitoring, SIEM and SOAR

Security monitoring centralizes audit logs, Security Command Center findings, VPC Service Controls policy denials, Cloud KMS activity, Cloud Armor events, firewall logs, container detections and identity activity. The SIEM correlates events across cloud, identity, endpoint and network domains. SOAR playbooks implement containment actions with strict guardrails and human approval for destructive operations.

29. Threat Modeling, STRIDE and Attack Path Analysis

Threat modeling is mandatory for new data domains, regulated data products, internet-facing analytics applications, AI agents, RAG retrieval flows and cross-perimeter data exchange. STRIDE is used to identify spoofing, tampering, repudiation, information disclosure, denial of service and elevation of privilege. Attack path analysis prioritizes toxic combinations, such as public exposure plus privileged service account plus sensitive dataset.

STRIDE category	Data platform example	Control response
Spoofing	Impersonated pipeline identity	WIF, service account impersonation, audit logs
Tampering	Modified Dataflow image or SQL artifact	Signed artifacts, code review, Binary Authorization
Repudiation	Untraceable data export	Audit logs, request reason, immutable evidence
Information disclosure	Restricted dataset copied to unmanaged project	VPC SC, IAM, masking, policy tags
Denial of service	Analytics portal DDoS	Cloud Armor, capacity limits, runbook
Elevation of privilege	Developer grants owner to self	PAM, deny policies, SCC finding, alert

30. Incident Response

Security incident response follows a standard lifecycle: detect, triage, classify, contain, preserve evidence, eradicate, recover and improve. Incidents involving Restricted or Regulated data require privacy, legal, compliance and business-owner notification paths. Every critical incident must produce a post-incident review, control improvement and regression test.

31. Regulatory Control Mapping

Control Area	NIST 800-53 / CSF	HIPAA	GDPR	PCI DSS	SOC 2	ISO 27001	Evidence
Identity governance	AC-2, AC-3, IA-2 / PR.AC	164.308(a)(4)	Art. 5, 25, 32	Req. 7, 8	CC6.1, CC6.2	A.5, A.8	IAM policy export, access review, PAM grant logs
Data perimeter	AC-4, SC-7 / PR.DS	164.312(a),(e)	Art. 32, 44	Req. 1, 3	CC6.6, CC6.7	A.8.12, A.8.16	VPC SC config, policy denied logs
Encryption and key management	SC-12, SC-13 / PR.DS	164.312(a)(2)(iv)	Art. 32	Req. 3.5, 3.6	CC6.1, CC6.7	A.8.24	KMS IAM, rotation, key access logs
Sensitive data protection	PT-2, SI-12 / PR.DS	164.312(a),(b)	Art. 5, 6, 25, 32	Req. 3, 4	CC6.1, CC6.7	A.8.11, A.8.12	SDP profiles, masking/tokenization evidence
Audit and detection	AU-2, AU-6, SI-4 / DE.CM	164.312(b)	Art. 30, 33	Req. 10	CC7.2, CC7.3	A.8.15, A.8.16	Audit sinks, SCC findings, SIEM tickets
Incident response	IR-4, IR-6 / RS.RP	164.308(a)(6)	Art. 33, 34	Req. 12.10	CC7.4, CC7.5	A.5.24, A.5.26	Incident tickets, tabletop exercise records

32. Security Testing and Penetration Testing

Security testing includes IAM negative persona tests, VPC Service Controls exfiltration tests, key access tests, Cloud Armor rule validation, firewall deny tests, supply-chain gate tests, incident tabletop exercises and penetration testing for externally exposed applications. Testing evidence is stored in the release-evidence repository and sampled during production readiness review.

33. Security Assurance and Architecture Review

Security assurance is a continuous process that combines architecture review, automated policy validation, operational evidence and independent testing. Every production data product must complete a Security Architecture Review Board checklist. Exceptions must include business justification, compensating controls, expiry date, risk owner and remediation plan.

34. Structured Google Cloud Service Assessments

The following assessments summarize the selected Google Cloud services for Volume 08. They do not replace current Google Cloud documentation, quota validation or product-specific implementation design.

Service	Purpose	Benefits	Limitations	Production evidence
Cloud Identity / Workforce Identity Federation	Federated human identity	SSO, MFA, group-based access, external workforce support	Requires IdP governance and lifecycle integration	User/group lifecycle, MFA, session logs
Workload Identity Federation	Keyless workload authentication	Avoids long-lived keys, supports CI/CD and cross-cloud workloads	Requires issuer trust and attribute mapping	Federation config, audit logs
IAM / IAM Conditions / Deny Policies	Authorization and least privilege	Fine-grained resource access and contextual conditions	Role sprawl and custom-role drift need governance	IAM policy exports, access review
Privileged Access Manager	JIT privileged access	Time-bound, approval-based elevation with auditability	Requires entitlement design and operating process	PAM grants, approvals, expiry logs
Organization Policy Service	Prevent unsafe configuration	Centralized guardrails across hierarchy	Exceptions and inheritance require careful testing	Org policy inventory and violations
VPC Service Controls	API perimeter and exfiltration reduction	Protects supported services with ingress/egress and context controls	Compatibility and dry-run testing required	Perimeter config and policy denied logs
Access Context Manager	Context-aware access	Device, IP, identity and custom access levels	Dependent on endpoint and IdP signal quality	Access level YAML and test results
Private Service Connect	Private service access	Private API and producer/consumer connectivity	Requires DNS and endpoint governance	PSC endpoint inventory
Cloud Armor	Edge WAF and DDoS protection	Preconfigured WAF rules and edge policies	Tuning and subscription tier may be required	WAF policy logs and test reports
Cloud Firewall	Network segmentation	Hierarchical, global and regional firewall policies	Does not replace IAM or API-level controls	Firewall rule logs
Security Command Center	Posture and threat management	Findings, vulnerabilities, compliance and threat sources	Tier selection and integration required	SCC findings and response tickets
Event Threat Detection	Threat detection from logs	Near-real-time anomaly and threat detection	Requires log availability and SCC tier	ETD findings and test events
Container Threat Detection	Container runtime detection	Detects common container runtime attacks	Requires supported SCC tier and environment	CTD findings and incident tickets
Secret Manager	Secret storage and rotation support	Versioned secret storage with IAM and audit logs	Secrets should be minimized and rotated	Secret inventory and access logs
Cloud KMS / Cloud HSM / Cloud EKM	Key management	CMEK, key rotation, HSM-backed and external key options	Service support and regionality must be validated	Key inventory, IAM, rotation, access logs
Sensitive Data Protection	Inspect and de-identify sensitive data	Profiling, masking, redaction, tokenization, pseudonymization	Requires tuning to reduce false positives/negatives	Templates, profiles, transforms
Access Transparency / Access Approval	Google personnel access visibility and approval	Transparency logs and explicit approval workflow	Supported services and operational impact must be validated	Access logs and approval records
Artifact Analysis / Binary Authorization	Supply-chain assurance	Vulnerability data and deployment attestation enforcement	Requires policy design and build integration	Scan results, attestations, blocked deployments

34.x Service assessment - Cloud Identity / Workforce Identity Federation

Federates employees, contractors and partners from the enterprise IdP with MFA, device posture and group lifecycle controls. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Federates employees, contractors and partners from the enterprise IdP with MFA, device posture and group lifecycle controls.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	SSO, MFA, group-based access, external workforce support
Benefits	SSO, MFA, group-based access, external workforce support
Limitations	Requires IdP governance and lifecycle integration Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	User/group lifecycle, MFA, session logs; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Workload Identity Federation

Allows workloads and deployment pipelines to access Google Cloud resources without persistent service account keys. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Allows workloads and deployment pipelines to access Google Cloud resources without persistent service account keys.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Avoids long-lived keys, supports CI/CD and cross-cloud workloads
Benefits	Avoids long-lived keys, supports CI/CD and cross-cloud workloads
Limitations	Requires issuer trust and attribute mapping Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Federation config, audit logs; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - IAM / IAM Conditions / Deny Policies

Provides least-privilege authorization, contextual policy and explicit prohibitions for high-risk actions. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Provides least-privilege authorization, contextual policy and explicit prohibitions for high-risk actions.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Fine-grained resource access and contextual conditions
Benefits	Fine-grained resource access and contextual conditions
Limitations	Role sprawl and custom-role drift need governance Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	IAM policy exports, access review; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Privileged Access Manager

Provides temporary, approval-based, auditable privilege elevation for administrators and responders. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Provides temporary, approval-based, auditable privilege elevation for administrators and responders.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Time-bound, approval-based elevation with auditability
Benefits	Time-bound, approval-based elevation with auditability
Limitations	Requires entitlement design and operating process Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	PAM grants, approvals, expiry logs; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Organization Policy Service

Imposes centralized guardrails across the Google Cloud resource hierarchy. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Imposes centralized guardrails across the Google Cloud resource hierarchy.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Centralized guardrails across hierarchy
Benefits	Centralized guardrails across hierarchy
Limitations	Exceptions and inheritance require careful testing Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Org policy inventory and violations; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - VPC Service Controls

Reduces Google Cloud API data exfiltration risk by creating service perimeters around sensitive projects. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Reduces Google Cloud API data exfiltration risk by creating service perimeters around sensitive projects.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Protects supported services with ingress/egress and context controls
Benefits	Protects supported services with ingress/egress and context controls
Limitations	Compatibility and dry-run testing required Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Perimeter config and policy denied logs; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Access Context Manager

Defines contextual access levels that can be used by VPC Service Controls and context-aware access decisions. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Defines contextual access levels that can be used by VPC Service Controls and context-aware access decisions.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Device, IP, identity and custom access levels
Benefits	Device, IP, identity and custom access levels
Limitations	Dependent on endpoint and IdP signal quality Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Access level YAML and test results; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Private Service Connect

Provides private API and producer-consumer service connectivity without broad network exposure. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Provides private API and producer-consumer service connectivity without broad network exposure.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Private API and producer/consumer connectivity
Benefits	Private API and producer/consumer connectivity
Limitations	Requires DNS and endpoint governance Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	PSC endpoint inventory; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Cloud Armor

Provides edge WAF, DDoS mitigation and request filtering for externally exposed applications and APIs. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Provides edge WAF, DDoS mitigation and request filtering for externally exposed applications and APIs.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Preconfigured WAF rules and edge policies
Benefits	Preconfigured WAF rules and edge policies
Limitations	Tuning and subscription tier may be required Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	WAF policy logs and test reports; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Cloud Firewall

Provides hierarchical and network firewall policy enforcement and logging for back-end network paths. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Provides hierarchical and network firewall policy enforcement and logging for back-end network paths.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Hierarchical, global and regional firewall policies
Benefits	Hierarchical, global and regional firewall policies
Limitations	Does not replace IAM or API-level controls Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Firewall rule logs; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Security Command Center

Centralizes posture, vulnerability, threat and compliance findings across Google Cloud assets. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Centralizes posture, vulnerability, threat and compliance findings across Google Cloud assets.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Findings, vulnerabilities, compliance and threat sources
Benefits	Findings, vulnerabilities, compliance and threat sources
Limitations	Tier selection and integration required Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	SCC findings and response tickets; positive and negative tests passed; runbook approved; ownere and escalation path documented.

34.x Service assessment - Event Threat Detection

Detects threats from Cloud Logging and Google Workspace logging signals and emits SCC findings. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Detects threats from Cloud Logging and Google Workspace logging signals and emits SCC findings.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Near-real-time anomaly and threat detection
Benefits	Near-real-time anomaly and threat detection
Limitations	Requires log availability and SCC tier Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	ETD findings and test events; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Container Threat Detection

Detects common container runtime attacks and suspicious container behavior. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Detects common container runtime attacks and suspicious container behavior.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Detects common container runtime attacks
Benefits	Detects common container runtime attacks
Limitations	Requires supported SCC tier and environment Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	CTD findings and incident tickets; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Secret Manager

Stores, versions and audits access to secrets that cannot be eliminated from workloads. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Stores, versions and audits access to secrets that cannot be eliminated from workloads.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Versioned secret storage with IAM and audit logs
Benefits	Versioned secret storage with IAM and audit logs
Limitations	Secrets should be minimized and rotated. Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Secret inventory and access logs; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Cloud KMS / Cloud HSM / Cloud EKM

Manages cryptographic keys, CMEK, hardware-backed keys and externally managed key integrations. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Manages cryptographic keys, CMEK, hardware-backed keys and externally managed key integrations.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	CMEK, key rotation, HSM-backed and external key options
Benefits	CMEK, key rotation, HSM-backed and external key options
Limitations	Service support and regionality must be validated. Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Key inventory, IAM, rotation, access logs; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Sensitive Data Protection

Profiles, inspects and de-identifies sensitive data using masking, redaction, tokenization and pseudonymization. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Profiles, inspects and de-identifies sensitive data using masking, redaction, tokenization and pseudonymization.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Profiling, masking, redaction, tokenization, pseudonymization
Benefits	Profiling, masking, redaction, tokenization, pseudonymization
Limitations	Requires tuning to reduce false positives/negatives Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Templates, profiles, transforms; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Access Transparency / Access Approval

Provides visibility and approval control for supported Google personnel access to customer data. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Provides visibility and approval control for supported Google personnel access to customer data.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Transparency logs and explicit approval workflow
Benefits	Transparency logs and explicit approval workflow
Limitations	Supported services and operational impact must be validated. Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation/; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Access logs and approval records; positive and negative tests passed; runbook approved; owner and escalation path documented.

34.x Service assessment - Artifact Analysis / Binary Authorization

Provides vulnerability metadata and deployment authorization gates for trusted artifacts. This assessment must be validated against current Google Cloud documentation for regional availability, service tiers, quotas, IAM roles, supported integrations, VPC Service Controls support and Terraform provider arguments at implementation time.

Assessment item	Volume 08 baseline
Purpose	Provides vulnerability metadata and deployment authorization gates for trusted artifacts.
Enterprise architecture role	Selected security control in the enterprise Zero Trust architecture; integrated with landing zone, data platform, analytics and AI workloads.
Business capabilities supported	Regulated data handling, secure self-service, auditability, risk reduction, operational resilience and compliance evidence.
Technical capabilities	Vulnerability data and deployment attestation enforcement
Benefits	Vulnerability data and deployment attestation enforcement
Limitations	Requires policy design and build integration Validate compatibility and support boundaries before enforcement.
Service quotas	Validate organization, project, request, policy, rule, finding, key, scan and API quotas during detailed design; do not assume defaults fit Fortune 100 scale.
Regional availability considerations	Confirm required locations, data residency, key location, service endpoint and regional control-plane behavior for AMER, EMEA and APAC.
High-availability characteristics	Use managed service HA characteristics; remove single project or single identity bottlenecks; test control-plane dependency failure modes.
Disaster-recovery considerations	Document recovery of configuration, policies, keys, logs, service agents and evidence repositories in Volume 12.
Security model	Least privilege IAM, group-based administration, change review, audit logs, policy-as-code and exception management.
IAM requirements	Separate admin, viewer, auditor, automation and service-agent roles; avoid broad basic roles; use PAM for elevation.
Network requirements	Use private management paths where possible and integrate with Shared VPC, PSC, firewall policies and controlled egress.
VPC Service Controls considerations	Validate supported products and interfaces; model ingress and egress; dry-run before enforcement; monitor policy denied logs.
Encryption capabilities	Use Google default encryption and CMEK/HSM/EKM where supported and justified by classification or regulation.
CMEK support	Validate product-level CMEK support, service-agent permissions, location compatibility and rotation behavior.
Logging	Route Admin Activity, Data Access where applicable, Policy Denied and product logs to protected central logging projects.
Monitoring	Expose control coverage, findings, denials, exceptions, latency and failure metrics to Cloud Monitoring and SIEM.
Alerting	Critical/high-risk control failures trigger on-call alert and incident workflow; low-risk drift is handled through backlog and review.
Cost drivers	Cost depends on service tier, log volume, scanning volume, key protection level, API calls, data processed and storage retention.
Cost optimization	Tune logging, retention, scan frequency, rule scope, subscription tiers and key count while preserving mandatory evidence.
Operational responsibilities	Platform security owns baseline; domain team owns workload use; SRE owns runbooks; audit/risk owns evidence review.
Integration points	Integrates with Terraform, Cloud Logging, SCC, IAM, CI/CD, GRC, SIEM/SOAR, data governance and incident management.
Alternatives	Alternatives include third-party tools or compensating controls, but they must not weaken mandatory Google Cloud-native controls without SARB approval.
Selection criteria	Select when it directly reduces identity, exfiltration, encryption, supply-chain, detection, privacy or compliance risk.
Best practices	Manage as code, test in non-production, use least privilege, maintain evidence, review exceptions, and automate validation.
Reference architecture	See the Volume 08 diagrams and Terraform/code examples included in this package.
Sample configuration	Representative examples are included in implementation; adapt only after environment-specific validation.
Common pitfalls	Overbroad exceptions, untested enforcement, unsupported API paths, unmanaged keys, direct grants and missing monitoring.
Anti-patterns	Project-owner grants, long-lived keys, public endpoints by default, wildcard egress, permanent break-glass, and manual-only evidence.
Production-readiness checklist	Scan results, attestations, blocked deployments; positive and negative tests passed; runbook approved; owner and escalation path documented.

35. Architecture Decision Records

ADR	Decision title	Decision
ADR-0801	Adopt Zero Trust security architecture for the data platform	Use identity, device, network, data and workload context for every request; do not trust project or network location alone.
ADR-0802	Use Workforce and Workload Identity Federation as the default identity integration model	Avoid unmanaged local identities and long-lived keys by federating enterprise users, external workforces and workloads.
ADR-0803	Use Privileged Access Manager for just-in-time elevated access	Replace standing privileged access with approved, time-bound, audited entitlements.
ADR-0804	Use VPC Service Controls for restricted data perimeters	Reduce API-based data exfiltration risk for restricted and regulated projects while explicitly modeling ingress and egress.
ADR-0805	Use Private Service Connect and private API paths for sensitive workloads	Keep producer and consumer traffic private and reduce internet exposure.
ADR-0806	Use Cloud KMS with CMEK, Cloud HSM and conditional EKM for sensitive workloads	Match key control to classification and regulatory constraints.
ADR-0807	Use Sensitive Data Protection for discovery, classification and de-identification	Standardize data inspection, masking, tokenization and profiling across domains.
ADR-0808	Centralize detection in Security Command Center and route evidence to SIEM/SOAR	Create a single prioritized security posture and threat signal path.
ADR-0809	Enforce supply-chain controls with Artifact Analysis and Binary Authorization	Prevent untrusted artifacts from reaching production workloads.
ADR-0810	Use Cloud Armor and Cloud Firewall for edge and network controls	Protect internet-facing services at the edge and enforce east-west/back-end allowlists.

Full ADR files are included in the /adrs folder of the implementation package. Each ADR includes problem, context, drivers, constraints, alternatives, rationale, tradeoffs, risks, mitigations, implementation implications, cost implications, security implications, operational implications, review triggers and review date.

36. Risks and Mitigations

Risk	Impact	Mitigation	Acceptance criteria
Security controls block production workload	Delivery delay	Dry-run, staged rollout, negative and positive tests	No enforcement until approved path tests pass
Standing privilege remains after migration	Unauthorized change risk	PAM rollout and quarterly access review	No permanent owner/editor in production
Sensitive data missed by profiling	Compliance exposure	Custom infoTypes, sampling, steward validation	Profiling precision/recall accepted by privacy team
Key rotation disrupts service	Availability impact	Service-agent IAM tests and pre-rotation validation	Successful non-prod rotation test
SCC findings not operationalized	Delayed response	SIEM/SOAR routing, severity taxonomy, on-call integration	Critical finding produces incident within SLO
Excessive log volume increases cost	FinOps impact	Log sampling where appropriate, tiered retention	Monthly logging cost review

37. Implementation Roadmap

Phase	Duration	Scope	Exit criteria
0 - Mobilize	2-3 weeks	Confirm scope, owners, regulated workloads, existing controls and product support	Approved security backlog and decision register
1 - Identity foundation	4-6 weeks	Federation, groups, IAM standards, PAM pilot, service account key restrictions	Pilot workloads run with keyless access and JIT admin
2 - Perimeter foundation	6-8 weeks	VPC SC dry-run, ACM access levels, PSC, firewall baselines	Negative exfiltration tests pass in non-production
3 - Crypto and privacy	6-8 weeks	KMS hierarchy, CMEK modules, SDP templates, data profiles	Restricted dataset protected by CMEK and profiled
4 - Detection and response	4-6 weeks	SCC, audit sinks, SIEM/SOAR, incident playbooks	Critical finding creates actionable incident
5 - Supply-chain enforcement	4-6 weeks	Artifact Analysis, Binary Authorization, signed provenance	Unsigned vulnerable artifact blocked from production
6 - Scale and optimize	ongoing	Control tuning, compliance evidence, quarterly reviews	Metrics show improved control coverage and reduced exceptions

38. Validation Criteria

- No production service account has user-managed keys unless exception-approved with expiry.
- Every Restricted or Regulated project has approved perimeter decision: enforced, dry-run with date, or documented exception.
- All production data products have owner, steward, classification, access model and key policy recorded.
- Critical SCC finding triggers SIEM/SOAR workflow and incident response within the approved SLO.
- PAM grants require justification, approval, expiry and post-use review.
- Cloud Armor and firewall controls are tested for externally exposed services.
- CMEK service-agent access is validated before production cutover.
- Supply-chain gate blocks unsigned or vulnerable production artifacts according to policy.

39. Production Readiness Checklist

Area	Check	Status evidence
Identity	Federation, groups, MFA, PAM and access reviews operational	IAM export, group review, PAM report
Network	PSC/private API paths, firewall logging and Cloud Armor policies validated	Network test report
Data perimeter	VPC SC dry-run/enforcement and ingress/egress policies validated	Perimeter test evidence
Crypto	KMS key rings, CMEK bindings, rotation and custodianship approved	KMS inventory and test results
Privacy	SDP profiles and de-identification templates approved	Privacy evidence pack
Monitoring	SCC, logs, SIEM/SOAR routing and alert severity tested	Alert test ticket
Supply chain	Artifact scanning, attestation and Binary Authorization gates active	Blocked-deployment test
Operations	Incident runbooks, escalation paths and tabletop completed	Runbook approval and exercise record
Compliance	Control mapping, exceptions and evidence repository ready	GRC evidence package

40. Decisions and Next Actions

Volume 08 approves the Zero Trust security baseline as the mandatory control foundation for subsequent volumes and production implementation. Volume 09 must reuse these controls in CI/CD and DevSecOps pipelines. Volume 10 must include security control cost drivers for logging, SCC tiers, Cloud Armor, KMS/HSM/EKM and scanning. Volume 11 must operationalize security SLIs, SLOs, dashboards and runbooks. Volume 12 must include security control recovery, key recovery and cyber-recovery dependencies. Volume 13 must convert the policy patterns into hardened Terraform modules.

- Approve baseline security control catalogue.
- Finalize regulated workload enrollment in Access Approval and Assured Workloads where applicable.
- Prioritize VPC Service Controls dry-run deployment for Restricted data projects.
- Create golden Terraform modules for IAM, VPC SC, KMS, firewall, SCC and logging.
- Schedule first security tabletop exercise and negative access test campaign.

41. References

- Google Cloud: Infrastructure security design overview - <https://docs.cloud.google.com/docs/security/infrastructure/design>
- Google Cloud IAM: Workforce Identity Federation - <https://docs.cloud.google.com/iam/docs/workforce-identity-federation>
- Google Cloud IAM: Workload Identity Federation - <https://docs.cloud.google.com/iam/docs/workload-identity-federation>
- Google Cloud IAM: Privileged Access Manager overview - <https://docs.cloud.google.com/iam/docs/pam-overview>
- Google Cloud: VPC Service Controls overview and ingress/egress rules - <https://docs.cloud.google.com/vpc-service-controls/docs/overview>
- Google Cloud: Access Context Manager overview - <https://docs.cloud.google.com/access-context-manager/docs/overview>
- Google Cloud: Security Command Center overview - <https://docs.cloud.google.com/security-command-center/docs/security-command-center-overview>
- Google Cloud: Event Threat Detection overview - <https://docs.cloud.google.com/security-command-center/docs/concepts-event-threat-detection-overview>
- Google Cloud: Container Threat Detection overview - <https://docs.cloud.google.com/security-command-center/docs/concepts-container-threat-detection-overview>
- Google Cloud: Sensitive Data Protection overview and pseudonymization - <https://docs.cloud.google.com/sensitive-data-protection/docs/sensitive-data-protection-overview>
- Google Cloud: Cloud KMS, CMEK, Cloud HSM and Cloud EKM documentation - <https://docs.cloud.google.com/kms/docs>
- Google Cloud: Cloud Armor overview - <https://docs.cloud.google.com/armor/docs/cloud-armor-overview>
- Google Cloud: Cloud Firewall documentation - <https://docs.cloud.google.com/firewall/docs>
- Google Cloud: Access Transparency and Access Approval documentation - <https://docs.cloud.google.com/assured-workloads/access-approval/docs>
- Google Cloud: Binary Authorization and Artifact Analysis documentation - <https://docs.cloud.google.com/binary-authorization/docs> and <https://docs.cloud.google.com/artifact-analysis/docs>